JÖNKÖPING UNIVERSITY
School of Engineering

Network and vulnerability scanning

Joakim Kävrestad

TODAY

- Six p´s of systems security
- Cyber kill chain
- Network scanning
- Host vulnerability scanning

LITTERATURE NOTE!

- Some of the lecture content is not covered by the book but may still appear on the exam

SYSTEMS SECURITY

- To maintain security of systems, we need to take measures
- In this lecture, we focus on individual devices
  - Securing devices is called device hardening
- Typically involves
  - Policies
  - Configuration
  - Protective systems
  - Testing (scanning)

6 P'S OF SECURITY

- *Note: this seems to me to be a product of this book, I have never heard of it before. Also, it seems like an odd way to talk about systems security.*
- Patch
- Ports
- Protect
- Policies
- Probe
- Physical

PATCH

- Systems needs to be kept updated to
  - Update features
  - Mitigate vulnerabilities
- Private machines typically benefit from automatic updates
- Updates in production environments should not be applied without review
  - Read patch notes
  - Test in test environment

PATCH

- Comes in different levels:
  - Important/critical: Must be applied to mitigate scary security issues
  - Recommended: Can include security updates but are not as important and can be omitted if you have a good reasons
  - Optional: Typicall include functionality updates and are optional

- Above is Microsoft terminology and other vendors may use other lables

PORTS

- Digital communication is addressed using IP addressing and port numbers
  - IP is used to identify a computer
  - Port is used to identify a service on that computer

- Most services are associated with specific port numbers
  - 80 is HTTP, for instance

PORTS

- A server will typically listen to incoming requests on ports of relevance
  - A web server would listen on port 80
- A client should typically not listen on any ports
  - But allow return traffic to requests sent
- Unused and unnecessary ports should be blocked in the firewall

PROTECT

- Includes ensuring that security software and appliances are installed and in place

- On the network level (Which really has nothing to do with device hardening)
  - Firewall
  - Possibly Intrusion detection systems

- On devices
  - Anti-malware
  - Firewall
  - Possibly intrusion detection systems

Reflect:1-2-4-all

Individually (60 Sec): Write core statements (one-liners) about what you learned in the last lecture part.

Pair up and compare lists (60 Sec) (add new things to your individual lists)

Pair the pairs and repeat (60 Sec)

Then one statement per group of four.

POLICIES

- Configurations and rules which dictate how compyter systems should be used

- Now that’s another chapter so lets skip this

- BUT!!!!!
  - Password complexity rules are bad
  - So are regular password changes….no matter what the book tells you!

PHYSICAL

- It is typically easier to mess with a device you can physically access
  - Password resets
  - Safe modes
  - Various cool physical exploits

- Thus, maintaining physical security is crucial for ensuring digital security

PHYSICAL

- Disaster protection
  - Water
  - Fire
  - ….?

- Theft protection

PROBE

- Probing the system is a common way to ensure that it is secure
- Security testing, pentesting, ethical hacking
- Basically means using hacking techniques to test the own system in different ways

A NOTE ON BACKUPS

- Backups are the single most important security measure as it allows you to get back on track

- Online vs offline backups
  - Online: quick restore
  - Offline: only protection against for instance ransomware
  - We need both!

- Test!

Reflect:1-2-4-all

Individually (60 Sec): Write core statements (one-liners) about what you learned in the last lecture part.

Pair up and compare lists (60 Sec) (add new things to your individual lists)

Pair the pairs and repeat (60 Sec)

Then one statement per group of four.

Questions?

CYBER KILL CHAIN

- Security testing involves thinking like a hacker
- Cyber kill chain is a model which outlines the steps in a typical attack, and then a pentesting procedure
- The scanning part is the first step

CYBER KILL CHAIN

Phases of the Intrusion Kill Chain

Reconnaissance	Research, identification, and selection of targets
Weaponization	Pairing remote access malware with exploit into a deliverable payload (e.g. Adobe PDF and Microsoft Office files)
Delivery	Transmission of weapon to target (e.g. via email attachments, websites, or USB drives)
Exploitation	Once delivered, the weapon's code is triggered, exploiting vulnerable applications or systems
Installation	The weapon installs a backdoor on a target's system allowing persistent access
Command & Control	Outside server communicates with the weapons providing "hands on keyboard access" inside the target's network.
Actions on Objective	The attacker works to achieve the objective of the intrusion, which can include exfiltration or destruction of data, or intrusion of another target

SCANNING

- Scanning aka recognisance intends to scan a network or a host to
  - Get information about it
  - Find vulnerabilities
- Typically involves a myriad of different tools
- We will end with looking at a few
  - NMAP and Metasploit are my favourites of those

NESSUS

- Enterprise network vulnerability scanner
- Scans network hosts for known vulnerabilities
- The list of vulnerabilities is constantly maintained

https://learn.microsoft.com/en-us/windows/security/operating-system-security/device-management/windows-security-configuration-framework/mbsa-removal-and-guidance

OWASP ZAP

- Open source web application scanner
  - Free to use for anyone

- Scans a web site for known web vulnerabilities

Untitled Session - 20160325-154016 - OWASP ZAP 2.4.3

File Edit View Analyse Report Tools Online Help

Standard Mode

Sites

- GET:Category:SAMM-ST-2
- GET:Category:OWASP_Tool
- GET:Category:OWASP_Release_Quality_Tool
- GET:2015-08-ZAP-ScriptingCompetition
- About_OWASP
- GET:File:ZAP-ScreenShotSearchTab.png
- GET:File:ZAP-ScreenShotHistoryFilter.png
- GET:File:ZAP-ScreenShotHelp.png
- GET:File:ZAP-ScreenShotAddAlert.png
- GET:File:Zap128x128.png
- GET:Category:Popular
- GET:Contributions

Quick Start | Request | Response

Welcome to the OWASP Zed Attack Proxy (ZAP)

ZAP is an easy to use integrated penetration testing tool for finding vulnerabilities in web applications.

Please be aware that you should only attack applications that you have been specifically been given permission to test.

To quickly test an application, enter its URL below and press 'Attack'.

URL to attack: http://www.owasp.org Select...

Attack Stop

Progress: Spidering the URL to discover the content

History | Search | Alerts | Output | Spider | Active Scan

New Scan Progress: 0: http://www.owasp.org 4% Current Scans: 1 | URIs Found: 7815

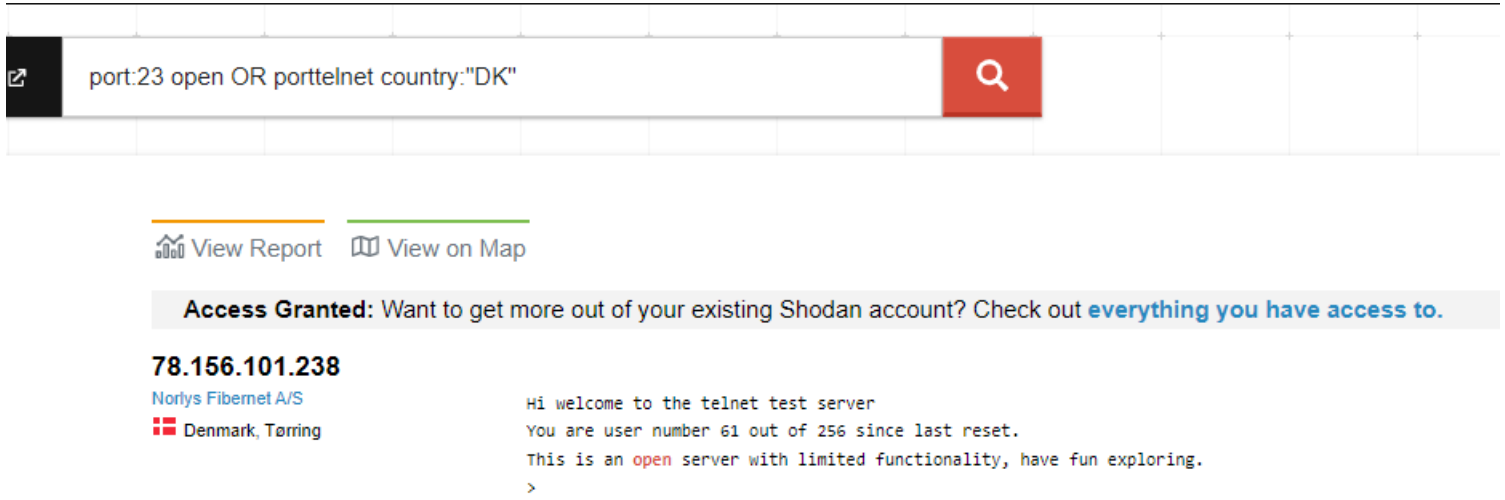
Processed	Method	URI	Flags
	GET	https://www.owasp.org/index.php/Mohd_Fazli_Azran	
	GET	https://www.owasp.org/index.php/John_Vargas	
	GET	https://docs.google.com/spreadsheets/d/1mO0e983giNVwhbuQ96cmb79t...	OUT_OF_SCOPE
	GET	https://www.owasp.org/images/d/da/WASPY_2015_Sponsorship_Docume...	
	GET	http://owasp.blogspot.com/2015/06/2015-waspy-award-nominations.html	OUT_OF_SCOPE
	GET	https://mail.google.com/mail/u/0/?ik=f64bf2af68&th=14e21153b3fe690d&ui...	OUT_OF_SCOPE
	GET	https://mail.google.com/mail/u/0/?ik=f64bf2af68&th=14e211c0353117cd&ui...	OUT_OF_SCOPE
	GET	https://twitter.com/owasp/status/613372502698532864	OUT_OF_SCOPE
	GET	https://www.facebook.com/groups/owaspfoundation/permalink/798497196...	OUT_OF_SCOPE
	GET	https://plus.google.com/116933056486234813396/posts/EFTauUZjyuE	OUT_OF_SCOPE
	GET	https://mail.google.com/mail/u/0/?ik=f64bf2af68&th=14e3182abfd79146&ui...	OUT_OF_SCOPE
	GET	https://twitter.com/owasp/status/614528448325771266	OUT_OF_SCOPE
	GET	https://plus.google.com/116933056486234813396/posts/1JcQN92vZHA	OUT_OF_SCOPE
	GET	http://owasp.blogspot.com/2015/06/nominate-your-waspy-candidates-today...	OUT_OF_SCOPE
	GET	https://www.facebook.com/groups/owaspfoundation/permalink/800341350...	OUT_OF_SCOPE
	GET	https://twitter.com/owasp/status/624676858127368194	OUT_OF_SCOPE

Alerts 0 1 6 0 Current Scans 0 0 0 0 1 0 0

SHODAN

- Online tool for searching for devices connected to the internet
- Collects information from devices connected to the internet by asking them
- Can give you a lot of very helpful information
- A nice thing is that you query the Shodan database rather than actively perform searches against a network

SHODAN


port:23 open OR porttelnet country:"DK"
View Report
View on Map
Access Granted: Want to get more out of your existing Shodan account? Check out everything you have access to.
78.156.101.238
Norlys Fibernet A/S
Denmark, Tørring
Hi welcome to the telnet test server
You are user number 61 out of 256 since last reset.
This is an open server with limited functionality, have fun exploring.
>

SHODAN

193.10.208.54

Regular View | Raw Data

General Information

castinginnovationcentre.se
www.castinginnovationcentre.se
child-pmh.se
www.child-pmh.se
hj.se
bibl.hj.se
www.bibl.hj.se
center.hj.se
edit.center.hj.se
www.center.hj.se
edit.hj.se
help.hj.se
hhj.hj.se
www.hhj.hj.se
hlk.hj.se
www.hlk.hj.se
hs.hj.se
www.hs.hj.se
ihh.hj.se
www.ihh.hj.se
intranet.hj.se

Open Ports

80 443

// 80 / TCP

```
HTTP/1.1 404
Content-Type: text/html;charset=utf-8
Content-Language: en
Content-Length: 682
Date: Tue, 17 Oct 2023 08:45:29 GMT
Strict-Transport-Security: max-age=63072000
```

// 443 / TCP

```
HTTP/1.1 404
Content-Type: text/html;charset=utf-8
Content-Language: en
Content-Length: 682
Date: Sat, 14 Oct 2023 21:50:57 GMT
Strict-Transport-Security: max-age=63072000
```

SHODAN

Shodan | Maps | Images | Monitor | Developer | More...

SHODAN | Explore | Downloads | Pricing | hostname:ju.se | Account

TOTAL RESULTS

33

TOP ORGANIZATIONS

HJ.SE network	20
HJ.SE network Jonkoping, SWEDEN	8
HJ.SE ipv6 network	3
Koneo	1

TOP PRODUCTS

Microsoft IIS httpd	7
Microsoft HTTPAPI httpd	5
nginx	4
Apache httpd	3
Cisco ASA SSL VPN	1

More...

View Report | View on Map

Access Granted: Want to get more out of your existing Shodan account? Check out **everything you have access to.**

193.10.239.254

2023-10-19T08:40:03.344789

ju-fg-bb2.bb2.hj.se
ju-fg2.dc.hj.se
vpn.ju.se
vpn.hj.se
ju-fg1.dc.hj.se
HJ.SE network
Sweden, Jönköping

SSL Certificate

Issued By:
|- Common Name:
GEANT OV RSA CA 4
|- Organization:
GEANT Vereniging

Issued To:
|- Common Name:
vpn.ju.se
|- Organization:
Stiftelsen Högskolan i Jönköping

Supported SSL Versions:
TLSv1.2, TLSv1.3

Diffie-Hellman Fingerprint:
RFC3526/Oakley Group 14

```
HTTP/1.1 200 OK
Date: Thu, 19 Oct 2023 08:41:55 GMT
ETag: "83-651328ab"
Accept-Ranges: bytes
Content-Length: 131
Content-Type: text/html
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self'; object-src 'self'; script-src 'self' https:  'unsafe-eval' 'unsafe-inline' b...
```

GRC Suite - interface utilisateur configurable, container : ACADEM

2023-10-19T00:13:05.828011

193.11.6.37
academp.win.hj.se
academ.ju.se
HJ.SE network Jonkoping, SWEDEN
Sweden, Jönköping

SSL Certificate

Issued By:
|- Common Name:
GEANT OV RSA CA 4
|- Organization:
GEANT Vereniging

Issued To:
|- Common Name:
academp.win.hj.se
|- Organization:
Stiftelsen Högskolan i Jönköping

Supported SSL Versions:
TLSv1.2, TLSv1.3

```
HTTP/1.1 200
Server: nginx/1.24.0
Date: Thu, 19 Oct 2023 00:13:04 GMT
Content-Type: text/html;charset=UTF-8
Content-Length: 14750
Connection: keep-alive
Set-Cookie: JSESSIONID=F5BFAA5625B45B0E46252EE3A0A60B8E; Path=/r1customui7; HttpOnly
Pragma: no-cache
Cache-Control: no-cache
Cache-Co...
```

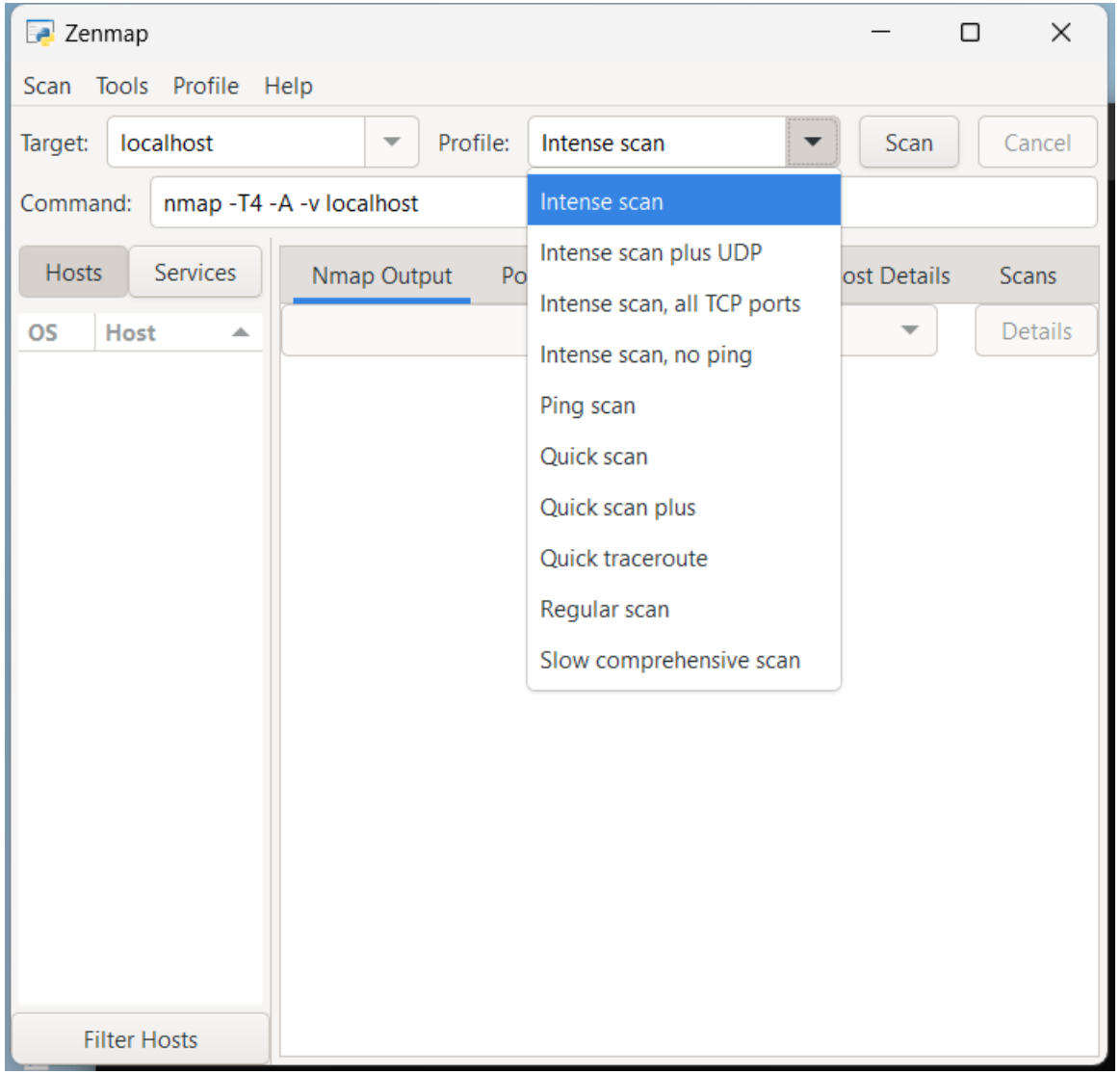
NMAP/ZENMAP

- Network scanning tool
  - Scanning for active hosts
  - Open ports
  - And sometimes identify OS and service software

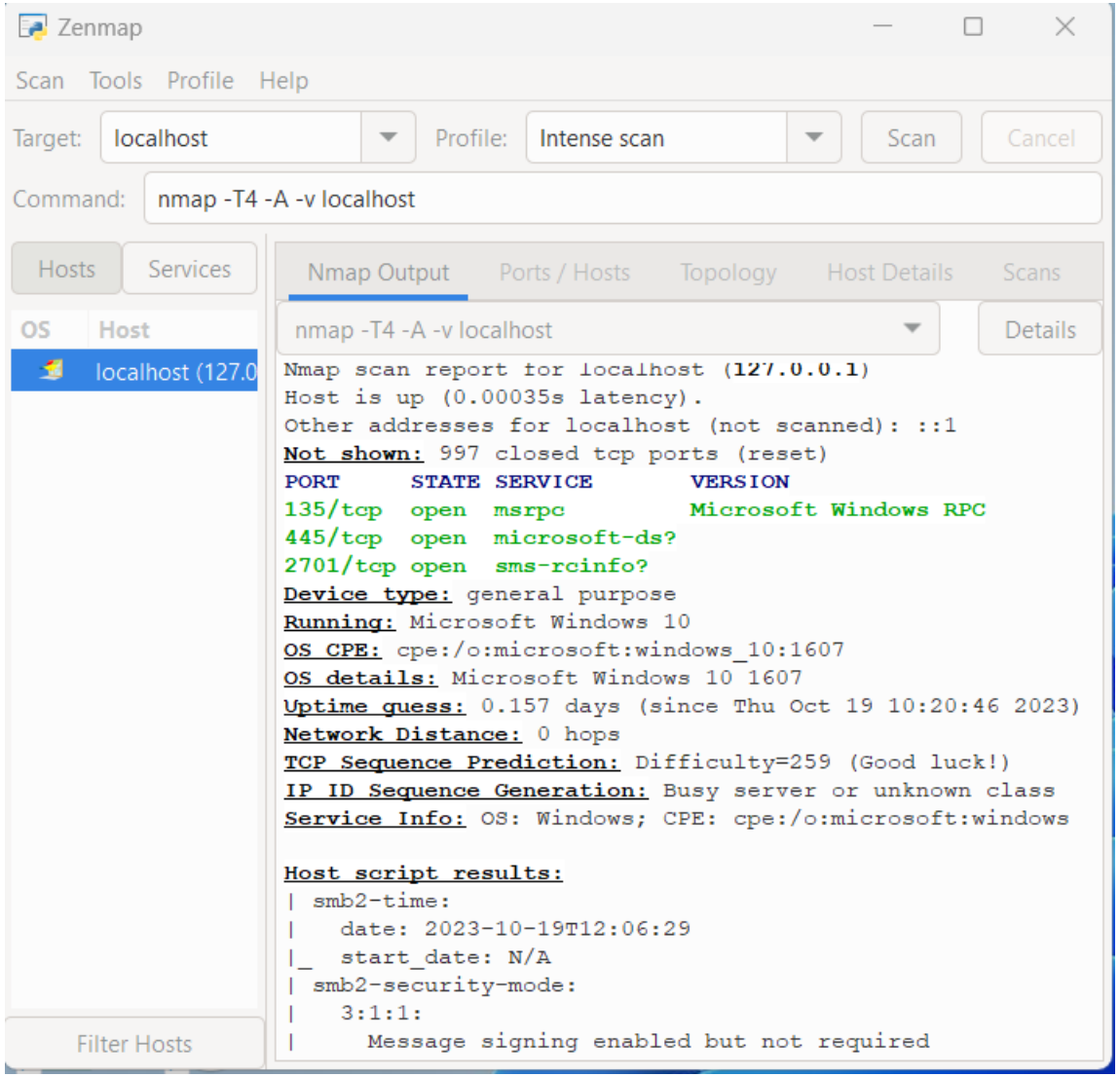
- By figuring out the info above, we can search for suitable vulnerabilities to use

- NMAP: CLI utility
- ZENMAP: Somewhat limited GUI

NMAP/ZENMAP


Zenmap
Scan
Tools
Profile
Help
Target:
localhost
Profile:
Intense scan
Scan
Cancel
Command:
nmap -T4 -A -v localhost
Intense scan
Intense scan plus UDP
Intense scan, all TCP ports
Intense scan, no ping
Ping scan
Quick scan
Quick scan plus
Quick traceroute
Regular scan
Slow comprehensive scan
Hosts
Services
Nmap Output
Scans
Details
OS
Host
Filter Hosts

NMAP/ZENMAP


Zenmap
Scan Tools Profile Help
Target: localhost
Profile: Intense scan
Scan
Cancel
Command: nmap -T4 -A -v localhost
Hosts
Services
OS Host
localhost (127.0
Nmap Output
Ports / Hosts
Topology
Host Details
Scans
nmap -T4 -A -v localhost
Details
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00035s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 997 closed tcp ports (reset)
PORT STATE SERVICE VERSION
135/tcp open msrpc Microsoft Windows RPC
445/tcp open microsoft-ds?
2701/tcp open sms-rcinfo?
Device type: general purpose
Running: Microsoft Windows 10
OS CPE: cpe:/o:microsoft:windows_10:1607
OS details: Microsoft Windows 10 1607
Uptime guess: 0.157 days (since Thu Oct 19 10:20:46 2023)
Network Distance: 0 hops
TCP Sequence Prediction: Difficulty=259 (Good luck!)
IP ID Sequence Generation: Busy server or unknown class
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
Host script results:
| smb2-time:
| date: 2023-10-19T12:06:29
|_ start_date: N/A
| smb2-security-mode:
| 3:1:1:
| Message signing enabled but not required
Filter Hosts

METASPLOIT

- Penetration testing framework
- Available as open source and in commercial edition
- Can do some searching, but is primarily a tool for exploiting vulnerable systems
- But we are not hacking today, so we will leave it there!

JÖNKÖPING UNIVERSITY

School of Engineering